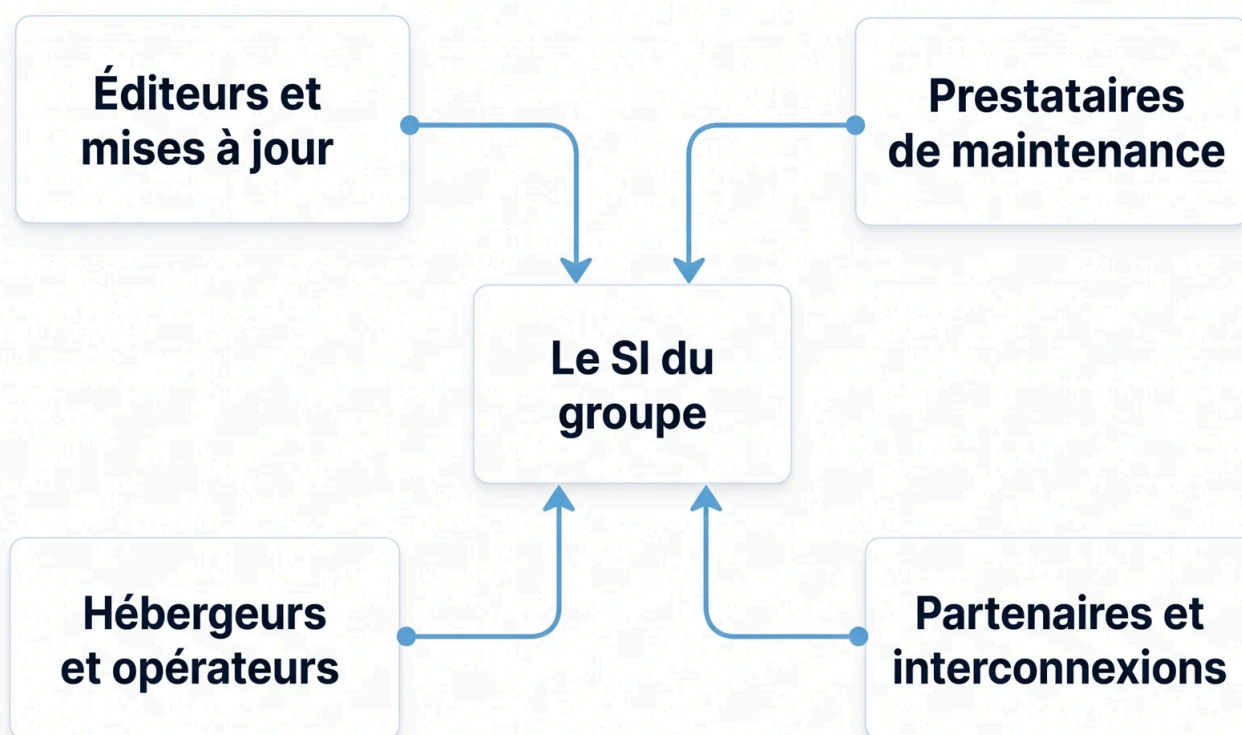


Le point du RSSI : Attaque de la chaîne d'approvisionnement

La question qui entre par la porte des fournisseurs



Chaque maillon détient déjà un accès

Objectifs de la séance

À l'issue de cette séquence :



- **Expliquer** ce qu'est la chaîne d'approvisionnement d'un système d'information et pourquoi elle est devenue un vecteur d'attaque de premier plan
- **Distinguer** une attaque directe d'une attaque par rebond, et dire ce que cette distinction change pour la défense
- **Identifier** le risque tiers du groupe MERIDIAN à partir de la cartographie construite en séance 2, sans attendre d'outil ni de méthode supplémentaire
- **Préparer** un point trimestriel de direction qui répond à une inquiétude médiatique par des faits sourcés et une décision à prendre

Prérequis

- La vue de l'écosystème de la cartographie de séance 2 : les parties avec lesquelles le SI de la filiale instruite interagit, lues aux S3 et S6 du dossier de filiale. C'est le matériau de travail de ce matin.
- Les valeurs métier et biens supports par filiale (séance 2), et le Top 5 des actifs critiques.
- La gouvernance posée en séance 1 : le « Point du RSSI (responsable de la sécurité des systèmes d'information) » trimestriel présenté au Comité de Direction, et la position d'arbitre des conflits inter-filiales tenue par le RSSI Groupe.
- L'appréciation du risque entamée en séance 5 : le cadrage, le socle de sécurité et les couples source de risque / objectif visé du dossier D5.

Ce qu'il faut savoir avant l'exercice

Trois notions suffisent pour traiter le cas de ce matin. Le reste de la journée les outillera, mais le raisonnement, lui, se mène dès maintenant avec la cartographie.

D'abord le problème. Depuis la séance 1, tout ce qui a été protégé appartenait au groupe : ses réseaux, ses applications, ses données. Or une organisation ne produit presque rien seule. Elle achète des logiciels et leurs mises à jour, confie sa maintenance à des prestataires, expose des interfaces à ses clients et partenaires, dépend d'hébergeurs et d'opérateurs. **La chaîne d'approvisionnement** d'un système d'information, c'est cet ensemble de fournisseurs, de prestataires et de flux entrants dont le SI dépend pour fonctionner : matériel, logiciels, mises à jour, services, maintenance. Sa mécanique de risque tient en une phrase : chaque maillon dispose, par construction, d'un accès ou d'une influence sur le SI de l'organisation que n'aura jamais un attaquant extérieur, et compromettre le maillon revient à hériter de cet accès. Sa limite comme concept : elle ne se voit pas dans un organigramme, car la plupart de ces dépendances sont contractées par les métiers, filiale par filiale, sans passer par le RSSI.

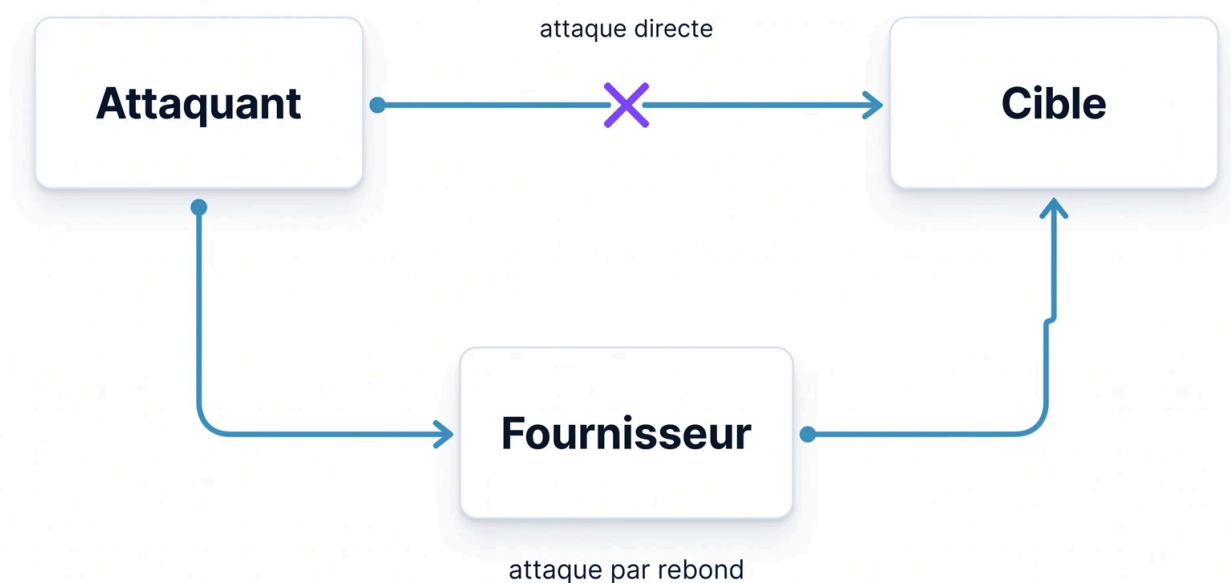
Deux affaires réelles fixent les idées, et elles serviront toute la journée. La première : NotPetya, le maliciel destructeur apparu le 27 juin 2017. La page d'alerte de la CISA (agence fédérale américaine de cybersécurité) documente son mécanisme de distribution : la mise à jour d'un logiciel de comptabilité fiscale ukrainien, M.E.Doc, dont l'environnement de l'éditeur avait été compromis. Les victimes n'ont pas été piratées une à une : elles ont installé, en confiance, la mise à jour d'un logiciel légitime. Parmi les dégâts collatéraux les mieux documentés,

l'armateur A.P. Moller-Maersk a chiffré dans sa communication financière un impact de 250-300 millions de dollars sur ses activités Transport & Logistics au troisième trimestre 2017.

Maersk n'était pas la cible : il était client du mauvais logiciel, au mauvais moment. La seconde affaire : SolarWinds. La déclaration conjointe du FBI, de la CISA, de l'ODNI (le bureau du directeur du renseignement national) et de la NSA évalue à environ 18 000 le nombre de clients publics et privés du produit SolarWinds Orion ayant reçu la mise à jour piégée de cet outil de supervision, lors de la campagne découverte en décembre 2020, un nombre bien plus faible ayant ensuite subi des actions de l'attaquant. L'asymétrie à retenir : une seule compromission chez l'éditeur, des milliers d'organisations touchées, et l'attaquant choisit ensuite ses vraies cibles dans le lot.



L'attaque par rebond, ensuite. C'est le mode opératoire qui exploite cette réalité : plutôt que d'attaquer frontalement une cible bien défendue, l'attaquant compromet d'abord un acteur qui dispose d'un accès légitime à elle, puis « rebondit » depuis cet acteur. Le rebond peut passer par un logiciel (la mise à jour piégée de NotPetya et de SolarWinds), par un prestataire (le compte de télémaintenance qui entre sans mot de passe fort), ou par une interconnexion (le partenaire dont le réseau touche celui de l'organisation). La logique de l'attaquant est une logique de moindre effort : pourquoi forcer une porte blindée quand un fournisseur en détient la clé et la protège moins bien ? La limite de la notion : « rebond » décrit le chemin, pas la gravité ; un rebond peut aboutir à un vol de données mineur comme à un arrêt complet de production.



Le risque tiers, enfin, est la traduction en gouvernance : c'est la part du risque qui naît chez des acteurs que l'organisation ne contrôle pas directement, mais dont elle a accepté, par contrat ou par usage, la présence dans son système. Il se gère, il ne se supprime pas : renoncer à tout tiers signifierait tout réinternaliser, ce qu'aucune direction ne financera. Et il se mesure déjà : selon le baromètre CESIN (club des experts de la sécurité de l'information et du numérique) publié en 2026, 35 % des cyberattaques significatives subies par les entreprises sont passées par des attaques indirectes via des tiers, ce qui en fait le troisième vecteur d'entrée. Ce chiffre est la pièce d'ouverture pour le Comité de Direction : le sujet n'est ni théorique ni marginal.

💡 Réflexe de méthode : quand un incident « chez un fournisseur » est rapporté, poser toujours les deux questions dans cet ordre : que peut faire ce fournisseur sur mon SI en temps normal (accès, flux, mises à jour) ? Et qu'est-ce qui m'alerterait si ce pouvoir était utilisé par quelqu'un d'autre ? La première question mesure l'exposition, la seconde la capacité de détection. Une réponse vide à la seconde est déjà un constat.

Exposition

Que peut faire ce fournisseur sur mon SI en temps normal ?

Détection

Qu'est-ce qui m'alerterait si ce pouvoir était utilisé par quelqu'un d'autre ?

— Une réponse vide à la seconde est déjà un constat

✓ Cas pratique : le point trimestriel sous pression médiatique

Mise en situation et énoncé

Le « Point du RSSI » trimestriel au Comité de Direction a lieu jeudi. Dimanche soir, la Directrice Générale transfère au RSSI Groupe une enquête de presse consacrée aux attaques de la chaîne d'approvisionnement, avec ce message : « Ce qui est arrivé aux clients de ce logiciel de comptabilité, est-ce que cela peut nous arriver par un de nos prestataires ? Je veux que votre point de jeudi commence par la réponse. »

Le RSSI Groupe n'a ni le temps ni le besoin de lancer une nouvelle étude d'ici jeudi : il dispose de la cartographie de séance 2, dont la vue de l'écosystème, et des constats déjà établis dans le module. En voici quatre, bien connus. Chez MERIDIAN Logistique, la TMA (tierce maintenance applicative) du WMS (système de gestion d'entrepôt), c'est-à-dire le prestataire de tierce maintenance applicative du logiciel de gestion d'entrepôt, intervient avec un compte de domaine partagé, dont personne ne sait combien de personnes l'utilisent (dossier Logistique S5).

Entre Logistique et Santé, l'API (interface de programmation) d'approvisionnement d'urgence, sur VLAN (réseau local virtuel) dédié avec pare-feu d'inspection, reliait les scannettes d'entrepôt au système de gestion des stocks pharmaceutiques de la filiale Santé ; le flux est coupé depuis trois mois à la demande du RSSI de la filiale Santé, et le Pharmacien chef en demande la reprise (S6 des deux dossiers). Chez MERIDIAN Éducation, le portail des 45

000 comptes est hébergé chez un infogérant qui confie la sauvegarde à un sous-traitant de second rang absent du contrat, et onze abonnements à des services en ligne échappent à l'inventaire, sur des moyens restreints (§2 et §4). Chez MERIDIAN Territoires, la plateforme de services aux citoyens sert une trentaine de collectivités clientes, les journaux y sont conservés localement, et l'infogérant du mobilier urbain détient les clés de chiffrement des transactions (§2 et §4).

Le travail de ce matin : préparer la partie « chaîne d'approvisionnement » du point de jeudi. Pas un cours à la direction, une réponse : où le groupe est-il exposé, qu'en sait-on déjà, que demande le RSSI Groupe.

Questions guidées

1. **Recenser** les dépendances tiers de la filiale instruite, lues aux §3 et §6 de son dossier de filiale, plus les dépendances de groupe du §5 du dossier de référence : construire un tableau à quatre colonnes (tiers ou flux entrant, filiale concernée, nature de l'accès ou de la dépendance, ce qu'il peut atteindre). S'appuyer sur la vue de l'écosystème de séance 2 et sur les quatre constats de l'énoncé ; ne pas se limiter aux prestataires sous contrat, un flux de mise à jour logicielle est aussi une dépendance.
2. **Qualifier** chaque ligne du tableau en une phrase : qu'est-ce qui en ferait un chemin de rebond intéressant pour un attaquant ? Reasonner en logique de moindre effort, du point de vue de l'attaquant.
3. **Transposer** les deux affaires de l'exposé au groupe : pour le mécanisme « mise à jour logicielle piégée », désigner l'endroit du groupe qui y ressemble le plus ; pour le mécanisme « accès de maintenance détourné », faire de même. Justifier chaque choix par un élément du dossier, pas par une intuition. Pour chacun des deux mécanismes, nommer la clause contractuelle qui aurait aidé.
4. **Rédiger** les trois messages du point de jeudi : un constat sourcé qui cadre le sujet, une phrase honnête sur l'exposition du groupe, une décision demandée au Comité de Direction. Contrainte : rien de ce qui est affirmé ne doit dépasser ce que le matériau prouve.
5. **Formuler** ce que l'analyse de ce matin ne sait pas encore faire : qu'est-ce qui manque pour passer de « voici nos dépendances » à « voici celles qui doivent être traitées en premier » ?

Méthode de travail

Compter 10 minutes pour les questions 1 et 2, la qualification de la question 2 tenant dans une colonne du tableau de la question 1 ; 10 minutes pour la question 3 ; 10 minutes pour les questions 4 et 5, la question 5 tenant en deux phrases. Travailler depuis les documents de séance 2, pas de mémoire : l'exercice mesure aussi la capacité à réutiliser la cartographie comme un actif, ce qu'elle est. Pour la question 4, écrire les phrases telles qu'elles seraient prononcées : un Comité de Direction n'écoute pas des généralités, il écoute ce qui engage. La réponse est une page écrite, individuelle, rangée dans le dossier de la séance 6 ; elle est notée sur 10 selon le barème du corrigé.



Corrigés et critères d'évaluation – cliquer pour révéler